

PHISHING & EMAIL ANALYSIS

I used two real phishing emails. I broke them down using headers, links, reputation checks and IOCs.

Header Forensics • Auth Checks •
Link Analysis • IOCs

Swipe to see how →

For both emails, I followed the same workflow:

First, look at the lure.

Then, check the headers.

Then, compare what the email claims against what the evidence actually says.

The goal was not to overcomplicate it.

The goal was to prove what was suspicious and why.

The first email pretended to be from Microsoft.

It used the normal phishing tactics: a scary login alert, a Russia location, a fake IP address, and a button that looked like it was there to protect the account.

“Report The User”

That is what made the lure work. It tried to make the user react fast.

Microsoft account

Unusual sign.in activity

We detected something unusual about a recent sign-in to the Microsoft account [phishing@pot](#).

Sign-in details

Country/region: **Russia/Moscow**

IP address: **103.225.77.255**

Date: **Fri, 08 Sep 2023 05:46:57 +0000**

Platform: **Windows 10**

Browser: **Firefox**

A user from **Russia/Moscow** just logged into your account from a new device, If this wasn't you, please report the user. If this was you, we'll trust similar activity in the future.

[Report The User](#)

To opt out or change where you receive security notifications, [click here](#).

Thanks,

The Microsoft account team

The email looked like Microsoft
on the surface.

But the Received chain showed
the message entering

Microsoft's mail gateway from
an unrelated domain and IP
address.

That was the first real proof that
this was not from Microsoft .

IOC:

thcultarfdes.co.uk

89.144.44.2

Received: from SJ0PR19MB6679.namprd19.prod.outlook.com (::1) by
MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Fri, 8 Sep 2023 05:47:06
+0000

Received: from DB8P191CA0014.EURP191.PROD.OUTLOOK.COM (2603:10a6:10:130::24)
by SJ0PR19MB6679.namprd19.prod.outlook.com (2603:10b6:a03:477::19) with
Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6768.30; Fri, 8 Sep
2023 05:47:04 +0000

Received: from DB8EUR06FT032.eop-eur06.prod.protection.outlook.com
(2603:10a6:10:130:cafe::9b) by DB8P191CA0014.outlook.office365.com
(2603:10a6:10:130::24) with Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6768.30 via Frontend
Transport; Fri, 8 Sep 2023 05:47:04 +0000

Authentication-Results: spf=none (sender IP is 89.144.44.2)
smtp.mailfrom=thcultarfdes.co.uk; dkim=none (message not signed)
header.d=none;dmarc=permerror action=none header.from=access-accsecurity.com;

Received-SPF: None (protection.outlook.com: thcultarfdes.co.uk does not
designate permitted sender hosts)

Received: from thcultarfdes.co.uk (89.144.44.2) by
DB8EUR06FT032.mail.protection.outlook.com (10.233.253.34) with Microsoft SMTP
Server id 15.20.6768.30 via Frontend Transport; Fri, 8 Sep 2023 05:47:04
+0000

X-IncomingTopHeaderMarker:

OriginalChecksum:6DB22130536EEE635A126CD816D1A4DDD37580CD58231D7469764E41AA1094B1
7E03028C1;SizeAsReceived:385;Count:12

From: Microsoft account team ,_<no-reply@access-accsecurity.com>

Subject: Microsoft account unusual signin activity

To: phishing@pot

Content-Length: 18708448

Content-Length: 1821750

Date: Fri, 8 Sep 2023 05:47:04 +0000

Reply-To: sotrecognizd@gmail.com

This was one of the clearest findings in the first sample.

SPF was none.

DKIM was none.

DMARC had a permerror with no action.

The email was pretending to be trusted, but the authentication results did not support that story.

```
Authentication-Results: spf=none (sender IP is 89.144.44.2)
  smtp.mailfrom=thcultarfdes.co.uk; dkim=none (message not signed)
  header.d=none; dmarc=permerror action=none header.from=access-accsecurity.com;
Received-SPF: None (protection.outlook.com: thcultarfdes.co.uk does not
  designate permitted sender hosts)
Received: from thcultarfdes.co.uk (89.144.44.2) by
```

The button looked like a Microsoft security action.

But the HTML showed something else.

“Report The User” did not go to Microsoft.

It opened a mailto link addressed to a personal Gmail account.

The label said security.

The destination said phishing.

IOC callout:

sotrecognizd@gmail.com

T1566 — Phishing

```
<td style="background-color: #2672ec; min-width: 50px; padding: 5px 20px 5px 20px;" bgcolor="#2672ec"><a id="i11" style="font-family: 'Segoe UI Bold', 'Segoe UI', 'Helvetica Neue Medium', Arial, sans-serif; font-size: 14px; text-align: center; text-decoration: none; letter-spacing: 0.02em; color: #fff;" href="mailto:sotrecognizd@gmail.com?&cc=sotrecognizd@gmail.com&subject=User Report The User">Report The User</a></td>
```

“Immediate Verification Required”

The second email used a different brand, but the same pressure tactic. It impersonated Binance and warned that the account would be disabled if the user did not update their information.

No complicated wording, just urgency and fear.

```
Immediate Verification Required
Dear phishing@pot ,
Thank you for using Binance.
We were reviewing all account information and we noticed that your information has been expired.
Your withdrawals are disabled until you update your informations.

UPDATE INFORMATION

Important Notice:If you don't update your information within 72 hours, your account will get disabled permanently!

Binance TeamThis is an automated message, please do not reply.
```

This sample was crazy because DMARC did fail the spoof.

But the enforcement action was still none.

That means the authentication check saw the problem, but the policy did not turn that failure into a block. The sending infrastructure traced back to what looks like a compromised legitimate hosting account, not purpose built attacker infrastructure.

```
Authentication-Results: spf=none (sender IP is 84.34.166.151)
  smtp.mailfrom=ilonasavola.com; dkim=none (message not signed)
  header.d=none;dmarc=fail action=none header.from=ses.binance.com;
Received-SPF: None (protection.outlook.com: ilonasavola.com does not designate
  permitted sender hosts)
Received: from smtp2.wp-cloud.fi (84.34.166.151) by
  HE1EUR01FT054.mail.protection.outlook.com (10.152.1.61) with Microsoft SMTP
  Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
  15.20.5546.15 via Frontend Transport; Mon, 22 Aug 2022 21:39:41 +0000
X-IncomingTopHeaderMarker:

OriginalChecksum:48D9ED7F8E6C684C899AAEED9CF3C2A1019DF0B1FE935A23738FDEBF3B1E764E;UpperCasedChecksum:46EDBBADCB56A90969382E01839D65AB0
AE41360F0;SizeAsReceived:636;Count:10
To: phishing@pot
Subject: =?UTF-8?Q?[Bin=D0=B0n=D1=81=D0=B5]_lmmmediate_verification_required_for_ro?= =?UTF-8?Q?drigo-f-p@hotmail.com?=
Date: Mon, 22 Aug 2022 21:39:41 +0000
From: Binance <do-not-reply@ses.binance.com>
Reply-To: do-not-reply@ses.binance.com
Message-ID: <a6e2feecb5be84894fdbdba6447a7b10@ilonasavola-com.staging.hel2.wp-cloud.dev>
Content-Type: multipart/alternative;
  boundary="b1_a6e2feecb5be84894fdbdba6447a7b10"
Content-Transfer-Encoding: 8bit
Authentication-Results-Original: smtp2.wp-cloud.fi;      auth=pass
  smtp.auth=outgoing@smtp.wp-cloud.fi smtp.mailfrom=wpcloud@ilonasavola.com
X-IncomingHeaderCount: 10
Return-Path: wpcloud@ilonasavola.com
```

Instead of searching for the button text, I searched the email for link structure.
That pulled out the actual href value and exposed the destination behind the message.

This is the repeatable part of the workflow: do not hunt for the words.

Hunt for what can actually take action.

IOC callout:

zzdzw.com

MITRE:

[T1566.002 — Spearphishing Link](#)

```
>> Foreach-Object { $_.Matches.value } | Sort-Object -On  
href="https://zzdzw.com/"  
PS C:\Users\calip\Labs\Lab5-Phishing\samples>
```

2 detections out of 92 might not look serious.

But that is the wrong way to read it.

The tools that flagged it were phishing focused reputation engines, which made the result more meaningful than the number alone.

Low detection does not automatically mean clean.

2
/ 92

Community Score

2/92 security vendors flagged this URL as malicious

https://zzdzw.com/
zzdzw.com

Last Analysis Date
1 day ago

DETECTION

DETAILS

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

alphaMountain.ai	ⓘ Malicious	Forcepoint ThreatSeeker	ⓘ Malicious
Abusix	✓ Clean	Acronis	✓ Clean
ADMINUS Labs	✓ Clean	All abs (MONITORAPP)	✓ Clean

The useful part was not just the VirusTotal ratio.

The details showed phishing reputation, newly registered infrastructure, the final URL, the serving IP, and the body hash.

That gave me enough to document the IOCs and map the behavior to MITRE.

IOC callout:

zzdzw.com

38.38.177.142

7eef3d901005d440c98cb303bc95eb67de05691cab0ec65ecedef10d2b89b42f

MITRE pills:

[T1566](#)

[T1566.002](#)

[T1027](#)

Categories ⓘ	
alphaMountain.ai	Malicious, Newly Registered (alphaMountain.ai)
Forcepoint ThreatSeeker	malicious web sites
History ⓘ	
First Submission	2022-07-13 16:58:07 UTC
Last Submission	2026-06-25 21:00:56 UTC
Last Analysis	2026-06-25 21:00:56 UTC
HTTP Response ⓘ	
Final URL	
https://zzdzw.com/	
Serving IP Address	
38.38.177.142	
Body SHA-256	
7eef3d901005d440c98cb303bc95eb67de05691cab0ec65ecedef10d2b89b42f	
Go to analysis	

